

Navigating the pitfalls of legacy software



Software and firmware used by your organisation

If hardware is the physical part of a server, computer, tablet or phone, **software** is the set of instructions that 'run' on the device. The operating system, programs and applications are all types of software. **Firmware** is another specific type of software embedded into the hardware of a device to make it function correctly and interact with other software installed on the device. Routers and firewalls contain firmware which acts as the operating system for those devices.

Software and firmware are supported by the manufacturer for a period of time after they have been developed. This support means that if a mistake or weakness, known as a vulnerability, is discovered in the product, the manufacturer will address it with an update or patch which fixes the problem before it can be exploited by cyber criminals.

Knowing which software and firmware you have and whether they are supported is really important. A list of software / firmware is sometimes referred to as a software asset list or inventory. Maintaining an asset inventory helps to track which software you have in use in your organisation. It is important to note that some software requires annual subscriptions to be in place to receive security updates.

Security updates prevent cyber criminals using the vulnerabilities they find in software as an access point to your systems

Patching

Software is made up of thousands of lines of code which is how the computer interprets information to complete its functions. In every 1000 lines of code there is on average 10-15 errors. Most of these errors are not noticeable to you as the user, however, each error is a potential opening for cyber criminals to access your data. These openings are often called 'vulnerabilities'. Within a piece of software's functioning life span, as soon as an error or 'vulnerability' is discovered, the manufacturer creates some additional code to correct the error. This is known as 'patching'. All modern software will need to 'update' on a regular basis (at least every 14 days) as part of its maintenance. This ensures that the latest vulnerabilities that have been discovered are patched within 14 days of the update being made available by the software vendor.

All software must be supported with regular security updates

You should make sure you have ways of keeping each of the following important types of software up to date:

Operating System (OS)

Firmware (in your firewalls and routers)

Web browser and extensions

All applications

Anti-virus

Unsupported / legacy/ end of life software

When software gets to a certain age, the manufacturer will cease to create and send out patches. At this point, the software is classed as 'legacy' or 'end of life' as it is no longer supported and therefore no longer secure to use. Not only are the vulnerabilities left un-patched, but they become common knowledge for hackers who create programmes and services to make them easy to exploit, even for criminals with low levels of technical expertise.

The timescales at which devices and software become unsupported vary between vendors, and most will provide information on their websites.

Unsupported software should be removed from devices, however, if this isn't possible, it **can** be removed from the certification scope by moving it to a well-defined, segregated and separately managed sub-set that prevents all traffic to/from the internet.

Certifying only part of your organisation

Technically separating part of your IT infrastructure by creating a sub-set

In some cases it is not possible to have the whole organisation in scope, for example, if you want to use devices or software that do not meet the Cyber Essentials requirements because they are no longer supported by the manufacturer. In this case, you must have a way to technically separate what is in scope from what is not. This can be achieved by creating a **subset** using a **VLAN** or **firewall**, which controls access to the parts of the network that are included in the assessment in order to segregate and protect it from any vulnerabilities that occur from within the network that is out of scope. When you can not certify your whole organisation, you must be able to clearly describe what is included in the scope (eg, whole organisation excluding the development network). Please note, it is not unusual to need some professional help to achieve this.

There are over 300 specially trained cyber security companies around the UK who are licensed to certify against the Government's Cyber Essentials Scheme. They can offer help and support in preparation for the assessment. [Find one near you.](#)

A simple way to create a subset, or segregate your network

A flat network is when all devices in an organisation communicate across a single network which has not been segmented to improve security. This scenario has risks because if there is a vulnerability anywhere in the network, it threatens the security of everything. A notorious cyber attack against Sony Pictures in 2014 demonstrated to the world the dangers of a flat network. Attackers entered Sony's network in one part of the business but, due to the flat network structure across the whole of Sony, they were able to steal music, films and confidential documents from their servers all over the business and across the world.

Network segmentation would make it very difficult for an attacker to move from one part of the business to another. A firewall or VLAN can be used to create separate physical networks that do not communicate directly.

One simple way to move some laptops or mobile devices onto a network that is separate from your main business network is to **create a guest network**. You may already have come across guest networks when signing in to a student network at a school or university or when using the internet at your library or in a hotel. Although you are connected to the internet, you will not be on the main business network and therefore not able to access (or provide an access point) to their organisational data.